

Security Posture Architecture

Post-onboard multi-dimensional security assessment with Shamir 2-of-3 DEK sharding. Onboarding unchanged; recovery triggered by dashboard posture meter.

PLANNED

Owner: Al

Pre-audit design spec

KEK: zero changes

1

ONBOARDING " 7"8 STEPS, UNCHANGED

Unchanged

NEW WALLET

1

Welcome → "Get started"

2

PIN setup (8–12 digits) + confirm

3

Explore mode (empty dashboard)

4

Tap "Create new wallet"

5

Provisioning (seed → Argon2id → AES-256-GCM → vault)

6

KEK auto-enroll (biometric → H → HKDF(H||C) → wrap DEK)

7

Telemetry consent

8

FirstRunTour (5-step modal)

SEED IMPORT

1

Welcome → "Get started"

2

PIN setup (8–12 digits) + confirm

3

Explore mode (empty dashboard)

4

"Import seed phrase" + enter 12/24 words

5

Provisioning (validate → Argon2id → AES-256-GCM → vault)

6

KEK auto-enroll (biometric → H → HKDF(H||C) → wrap DEK)

7

Telemetry consent

No FirstRunTour on import path

Dashboard ready – wallet functional

7–8 steps · ~60–90 sec · KEK untouched · no recovery yet

2

SECURITY POSTURE ASSESSMENT

Post-onboard

Authentication

20 pts

PIN created

10

PIN ≥12 chars

5

Device Integrity

25 pts (RASP)

RASP scan clean

10

No root/jailbreak

5

Hardware Binding

15 pts

KEK active

5

StrongBox / SE

5

FaceID / Biometric5

No Frida/hook5

Play/App Attest5

TEE (lower tier)3

Recovery

30 pts

Passphrase set8

Share B (cloud)8

Share C exported6

Share C verified6

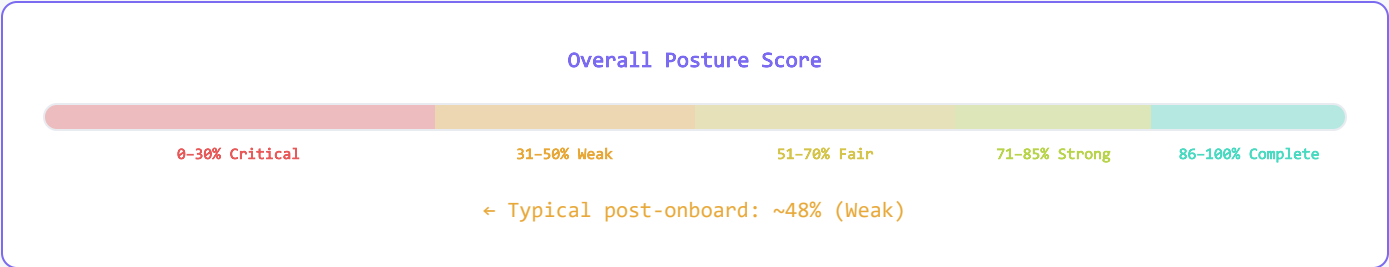
Session Security

10 pts

WC spend limit3

Expiry ≤24h3

Step-up re-auth4



BANNER SHOWS LOWEST-SCORING DIMENSION FIRST

First dashboard load

First incoming transaction

24h after creation

Settings → Security

Always skippable · 3-skip cooldown

3

RECOVERY SETUP – 6 STEPS, FILLS RECOVERY DIMENSION

From posture

- 1

PIN + biometric re-auth
- 2

Set recovery passphrase

Min 16 chars · strength meter · derived key (domain-separated)
- 3

Shamir split DEK (2-of-3, GF(2^8))

crypto.getRandomValues · → Share A + B + C
- 4

Display Share C as QR – "shown once"
- 5

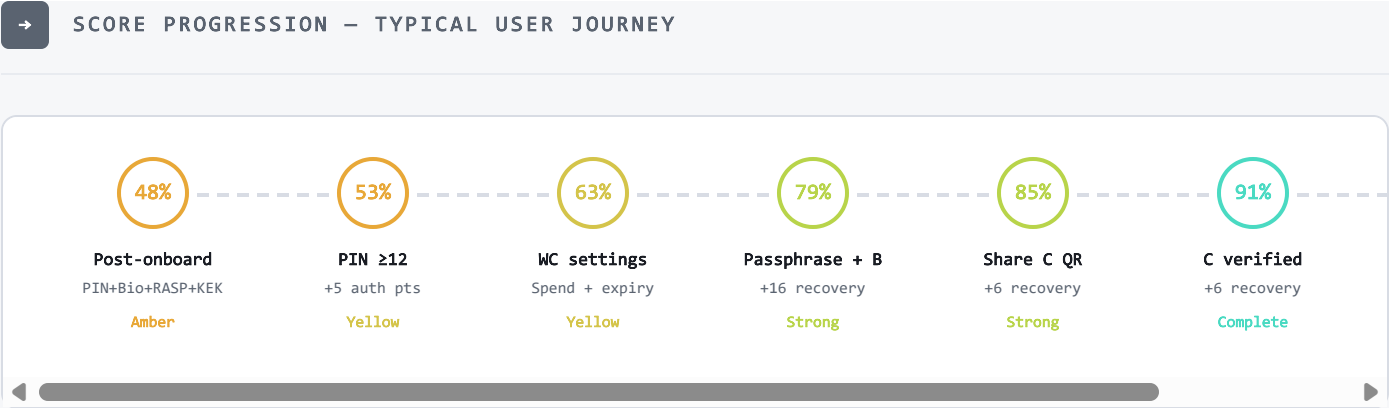
Scan to verify (constant-time compare)
- 6

Persist all shares

A → KEK-wrap → Keystore · B → RK-wrap → cloud · DEK cache → KEK-wrap

Recovery dimension → 30/30 · shield green

+30-45 sec when user is ready · KEK completely untouched



TEE users cap at 93% – honest about the hardware tier difference. 100% requires StrongBox or Secure Enclave.

✓ KEY PROPERTIES

KEK untouched

HKDF(H||C) – zero changes
combineKek – zero changes
Vault AES-256-GCM – zero changes
Shamir splits DEK after KEK wrapping

Multi-dimensional

Not just recovery readiness
RASP, auth, hardware all scored
Lowest dimension drives banner
Score computed live, not persisted

Honest scoring

TEE caps at 93% (not StrongBox)
RASP BLOCK = 0/25 (read-only)
Degradation is live + explained
Deniability: per-set, RASP shared